



MISE EN LIGNE

Audit avant mise en ligne

Bloquants, points importants et état de préparation du site

Date : 16 septembre 2026. Environnement audité : build de production local (`npm start`), base de données locale, dépôt GitHub `main`. Audit en lecture seule sur les données : aucun contenu n'a été modifié ni supprimé.

Légende : ● bloquant pour la mise en ligne · ● important · ● confort · ✅ prêt

Sommaire

Synthèse

1. Bloquants ●

1.1 Mise à jour de sécurité du CMS (technique) —  faite le 16/09/2026

1.2 Compte administrateur d'exemple

1.3 Contenus d'exemple encore publiés

1.4 Textes juridiques

1.5 Coordonnées professionnelles

1.6 Infrastructure et e-mail

2. Importants ●

3. Confort ●

4. Ce qui est prêt

5. Corrigé pendant l'audit

6. Ordre conseillé

Synthèse

Le socle technique est prêt ; le site ne l'est pas encore. Sécurité, performances, référencement, accessibilité, tests automatisés et sauvegardes sont en place et vérifiés. Ce qui bloque la mise en ligne relève du **contenu**, des **textes juridiques**, des **coordonnées** et de l'**infrastructure** (domaine, hébergement, e-mail), plus le remplacement du compte administrateur d'exemple. La mise à jour de sécurité du CMS est faite (1.1).

Domaine	État
Sécurité (en-têtes, API, secrets)	✅ solide, Payload 3.89 installé · ❌ compte administrateur à revoir
Performances	✅ mobile 83 en moyenne, ordinateur 98 – 100 (Lighthouse, 15/09)
Référencement	✅ sitemap, robots, hreflang, métadonnées · ⚠️ image de partage en SVG
Accessibilité	✅ WCAG 2.2 AA (axe) sans violation sur les pages auditées
Tests	✅ 456 E2E sur 4 navigateurs, CI GitHub verte avec E2E
Contenus	❌ 14 contenus d'exemple publiés, dont une conférence « test »
Textes juridiques	❌ les 5 pages attendent une validation juridique
Coordonnées	❌ e-mail et adresse vides (Impressum obligatoire)
Infrastructure	❌ domaine, hébergement, HTTPS, SMTP à mettre en place

1. Bloquants ❌

1.1 Mise à jour de sécurité du CMS (technique) — ✅ faite le 16/09/2026

`npm audit` sur les dépendances de production : **13 alertes** (12 modérées, 1 faible, aucune élevée ou critique) avec Payload 3.88.

Fait : Payload et ses paquets passés en **3.89.0**, DOMPurify forcé en **3.4.15** (`overrides` du `package.json` : l'éditeur de code de l'administration l'imposait en 3.4.8). Aucune migration de base nécessaire. Vérifié : TypeScript, lint, 149 tests unitaires, build, page de connexion de l'administration, 456 tests E2E sur 4 navigateurs. **Reste 5 alertes modérées**, toutes la même faille d'esbuild, arrivée par `drizzle-kit` (outil de migration) : elle ne touche que le serveur de **développement**, jamais le site en ligne ; elle disparaîtra avec une prochaine version de Payload.

Alerte	Portée réelle
Payload : un utilisateur connecté peut débloquer le verrouillage du compte d'un autre (GHSA-jg8r-5jh2-v2xj)	Administration uniquement ; risque faible avec un seul compte, mais à corriger avant d'ouvrir d'autres accès
DOMPurify ≤ 3.4.12 : contournements de nettoyage HTML pouvant mener à du XSS (4 alertes)	Éditeur de texte de l'administration ; contenus saisis par des comptes de confiance
esbuild ≤ 0.24.2 : le serveur de développement répond à n'importe quel site	Outils de développement seulement ; aucun effet en production

Alertes d'origine, pour mémoire (les deux premières lignes sont corrigées).

1.2 Compte administrateur d'exemple

La base contient **un seul compte**, administrateur, avec une adresse `@example.com` (compte créé par le script de démarrage). **Action** : créer le compte définitif avec l'adresse réelle et un mot de passe fort, vérifier la connexion, puis supprimer le compte d'exemple (checklist `DEPLOIEMENT.md` §13).

1.3 Contenus d'exemple encore publiés

Section	Publiés	Dont « Contenu d'exemple »	Action
Expériences et projets	3	3	Remplacer par les expériences vérifiées ou dépublier
Articles RK Insights	3	3	Décider : conserver, remplacer ou supprimer
Écosystème (activités)	5	5	Descriptions validées des 5 activités
Formations et certificats	2	2	Intitulés exacts
Conférences & médias	1	1	Fiche « test » publiée, en français seulement : la retirer
Domaines d'expertise	8	0	✅ (relecture DE/EN conseillée)
Livres	1	0	✅

Chaque contenu d'exemple affiche un bandeau « Contenu d'exemple » sur le site public : aucun ne doit rester publié le jour de l'ouverture.

Médiathèque : deux images de test (« ChatGPT Image 13 août 2026, 09_18_49.webp » et « download (17).webp ») ont pour texte alternatif « voila » et « voilawer », en français seulement. **Action** : les supprimer si elles ne servent pas, sinon leur donner un vrai texte alternatif dans les trois langues (lu par les lecteurs d'écran et les moteurs de recherche).

1.4 Textes juridiques

Les **5 pages légales** (Impressum, confidentialité, cookies, CGV, livraison et retours) portent toutes la case « à faire valider par un juriste » : bandeau visible, `noindex`, exclues du sitemap. **Action** : compléter (dénomination, siège, registre, TVA, responsable de traitement, durées de conservation, prestataires), faire valider, puis décocher la case.

1.5 Coordonnées professionnelles

Dans **Réglages du site** : **e-mail publié vide**, **adresse vide dans les trois langues** (le pied de page affiche « Adresse professionnelle à compléter »), téléphone vide. L'adresse est **obligatoire pour l'Impressum** en Allemagne.

1.6 Infrastructure et e-mail

Domaine, hébergement, HTTPS et compte SMTP ne sont pas encore en place (éléments 1.1 → 1.5 et 9.1 de `ELEMENTS_A_FOURNIR.md`). Sans SMTP réel, le formulaire enregistre les demandes mais n'envoie aucun e-mail, et la newsletter reste masquée. Le jour J, suivre la **checklist de mise en ligne** de `DEPLOIEMENT.md` (§13).

2. Importants

#	Constat	Action
2.1	Boutique ouverte dans l'administration (case cochée), TVA à 19 % , aucune adresse de notification des commandes. Aucun paiement n'est proposé tant que les clés manquent, mais la case ne doit pas rester cochée sans CGV validées	Décocher jusqu'à l'ouverture réelle ; faire valider le taux par le comptable (les livres relèvent en principe de 7 %)
2.2	Image de partage social absente : l'image générique est un SVG, que LinkedIn et Facebook n'affichent pas	Fournir une image JPG ou PNG 1200 × 630 (Réglages du site → SEO par défaut)
2.3	International Expert Profile et CV non téléversés : les boutons de téléchargement restent masqués	Téléverser les PDF (Réglages du site → Marque)
2.4	Réseaux sociaux : aucun profil, la section du pied de page est masquée	Ajouter au moins LinkedIn (guide administrateur §10)

#	Constat	Action
2.5	Échecs ponctuels de requêtes au CMS sous forte charge (<code>ECONNRESET</code>) : le site sert alors le contenu de démarrage, qui peut rester en cache 5 minutes	Chantier « fiabiliser le CMS » : limiter les connexions, ne pas mettre en cache le contenu de secours
2.6	HSTS envoyé avec <code>includeSubDomains; preload</code>	Garder seulement si tous les sous-domaines sont en HTTPS ; ne soumettre à la liste de préchargement qu'ensuite
2.7	Relectures DE/EN : biographie, domaines d'expertise, fiche livre	Relecture par un locuteur natif

3. Confort

- Lien de prise de rendez-vous non renseigné (bouton masqué).
- Logo : le monogramme « RK » du site est utilisé ; aucun logo n'est téléversé dans Réglages du site (décision du 15/09 : conserver le monogramme).
- Prix, éditeur, date de parution et nombre de pages du livre facultatifs.
- La 404 d'une **fiche** inexistante est complétée par JavaScript (statut 404 et `noindex` corrects) ; limite connue et acceptée.
- Plantages ponctuels de Node (code `0xC0000409`) observés sous Windows pendant les tests locaux ; à surveiller sur le serveur Linux (redémarrage automatique du conteneur prévu).
- Intégration CRM / e-mail marketing : décision ouverte (l'export CSV couvre le besoin immédiat).

4. Ce qui est prêt

Sécurité

- En-têtes vérifiés sur la réponse du serveur : `Content-Security-Policy`, `Strict-Transport-Security`, `X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff`, `Referrer-Policy`, `Permissions-Policy`, sans en-tête `X-Powered-By`.
- Administration en `X-Robots-Tag: noindex, nofollow` et exclue de `robots.txt`.
- API du CMS (`/api/cms`) : sans connexion, les collections privées (utilisateurs, demandes de contact, commandes, abonnés, membres, accès aux produits, fichiers protégés) et les réglages de la boutique répondent **403** ; les contenus publics ne renvoient aucun brouillon ; GraphQL désactivé. Contrôle automatisé dans `content.spec.ts`.
- `PAYLOAD_SECRET` refusé au démarrage s'il est vide, par défaut ou trop court ; CORS et CSRF limités à l'adresse du site.
- Aucun secret dans le dépôt ; aucun `console.log`, `TODO` ou `FIXME` oublié dans le code.
- Formulaire : validation serveur, anti-robot, limitation de débit ; paiements jamais simulés, webhook Stripe signé.

Performances et référencement

- Lighthouse (15/09, 12 pages) : mobile **83** en moyenne, ordinateur **98 – 100**, accessibilité et bonnes pratiques **100**.
- `sitemap.xml` (82 adresses) avec variantes de langue, `robots.txt`, balises canoniques et `hreflang`, données structurées, pages mises en cache 5 minutes.
- Médias : chaque image a un texte alternatif en français (voir 1.3 pour deux images de test sans version anglaise ni allemande).

Qualité et exploitation

- 149 tests unitaires, 131 scénarios E2E × 4 navigateurs (456 réussis), intégration continue GitHub avec E2E sur base jetable.
- Point de santé `/api/health` (base de données vérifiée), scripts de sauvegarde et de restauration testés, migrations versionnées, image Docker de production.
- Guides administrateur, installation, déploiement et rapport de tests en PDF.

5. Corrigé pendant l'audit

Constat	Correction
Le sitemap publiait des adresses vides (<code>/en/speaking/</code> , <code>/de/speaking/</code>) pour un contenu traduit dans une seule langue : un robot aurait suivi une adresse redirigée vers une liste	Une langue n'est plus listée quand le contenu n'y a pas de slug ; variantes <code>hreflang</code> idem
L'adresse de réception des demandes de contact (Réglages du site) était lisible par tous via <code>/api/cms/globals/site-settings</code> ; et le formulaire l'ignorait (envoi à <code>EMAIL_TO</code> , contrairement au texte d'aide)	Champ lisible par l'équipe seulement ; le formulaire l'utilise en priorité, puis <code>EMAIL_TO</code> , puis l'e-mail publié
Dépendances : 13 alertes (Payload 3.88, DOMPurify 3.4.8)	Payload 3.89.0 et DOMPurify 3.4.15 ; reste l'alerte esbuild de développement (1.1)

6. Ordre conseillé

1. **Technique** : ~~mise à jour Payload 3.89 (1.1)~~ faite ; reste le compte administrateur définitif (1.2).
2. **Contenus (commanditaire)** : retirer la fiche « test », remplacer ou dépublier les contenus d'exemple (1.3), coordonnées (1.5), réseaux sociaux, PDF et image de partage (2.2 → 2.4).
3. **Juridique (commanditaire + juriste)** : 5 pages légales (1.4) ; décocher la boutique tant que la vente directe n'est pas prête (2.1).
4. **Infrastructure** : domaine, hébergement, HTTPS, SMTP avec SPF/DKIM/DMARC (1.6).
5. **Jour J** : checklist `DEPLOIEMENT.md` §13, Lighthouse sur le domaine final, soumission du sitemap à la Search Console.